

Chapitre 1: Concepts de base

M1 RSI 2024-2025

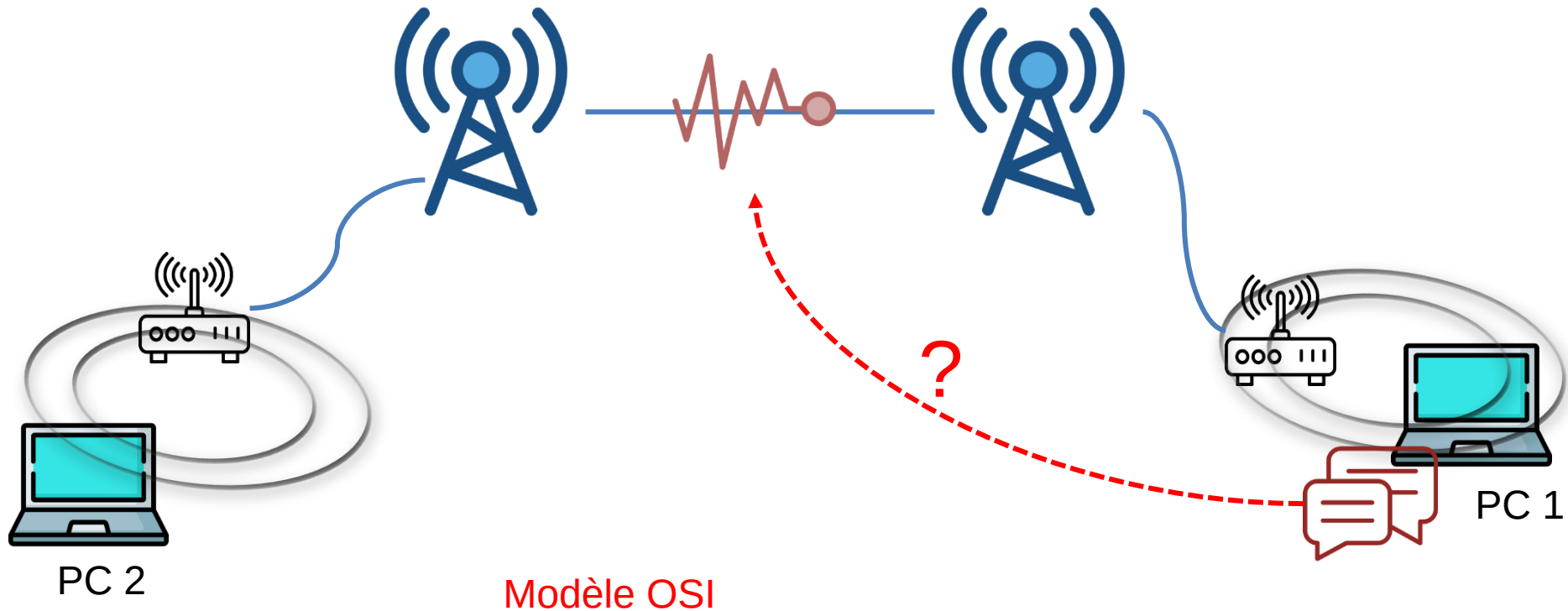
Prérequis

1. Cryptographie
2. Modèle TCP/IP
3. Notions de Base en Sécurité

Prérequis (Modèle TCP/IP)

1. Qu'est-ce qu'un réseau informatique ?
2. C'est quoi le rapport entre: Réseaux, Modèle TCP/IP ?

Prérequis (Modèle TCP/IP)



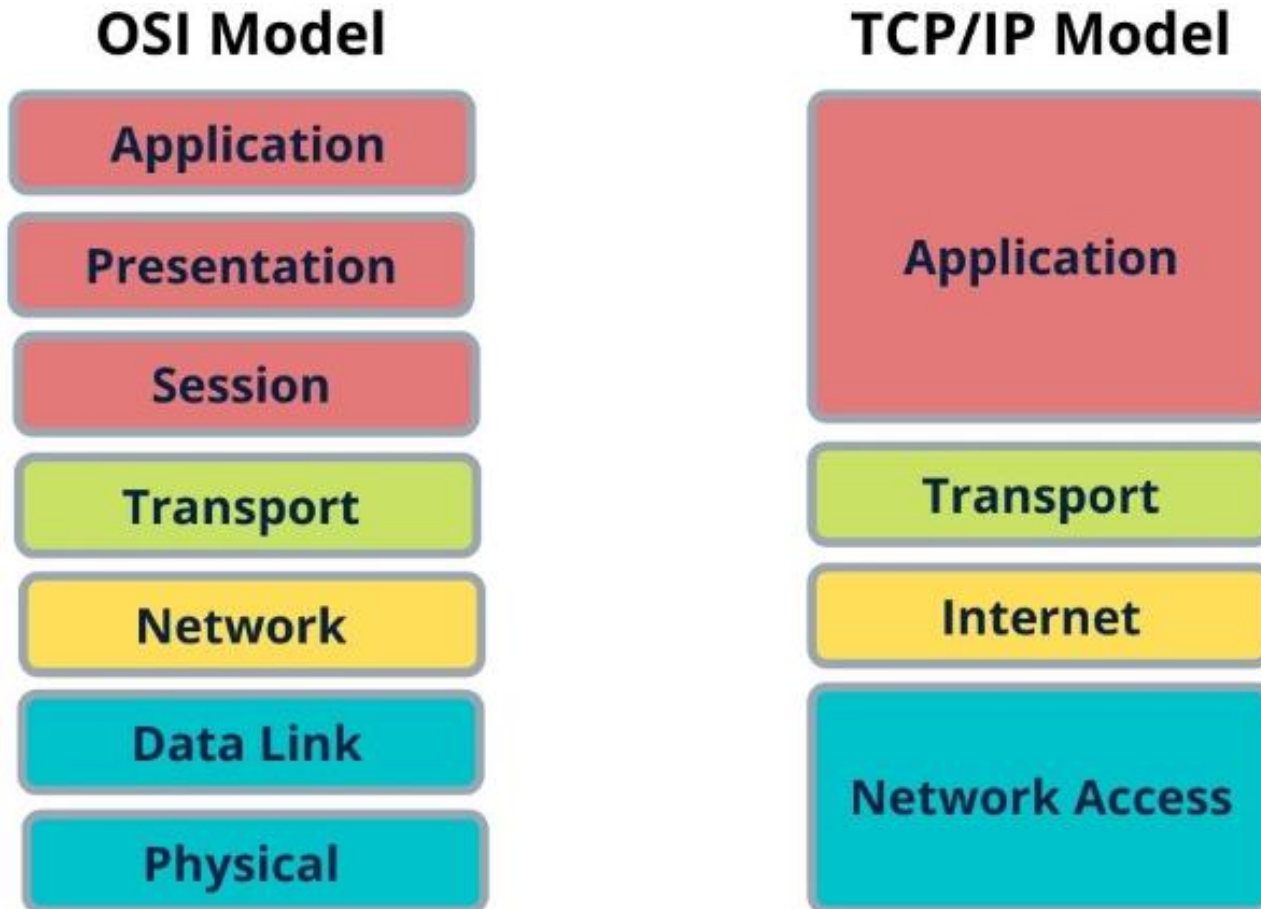
Prérequis (Modèle TCP/IP)

OSI Protocols

LAYER 7	APPLICATION LAYER	Works at user end to interact with applications. Protocols: <u>HTTP, SMTP, DHCP, FTP, Telnet, SNMP & SMPP</u>
LAYER 6	PRESENTATION LAYER	Encryption and decryption is defined here. It ensures data is transferred in standard format. Protocols: <u>XDR, TLS, SSL and MIME</u>
LAYER 5	SESSION LAYER	Creates and manages session between source & destination nodes Protocols: <u>PPTP, SAP, L2TP & NetBIOS</u>
LAYER 4	TRANSPORT LAYER	Determines communication mode. Connection oriented or connection less. Protocols: <u>TCP, UDP, SPX, DCCP & SCTP</u>
LAYER 3	NETWORK LAYER	Real time processing and transfer of data from node to node. Protocols: <u>IP, IPX, AppleTalk, ICMP, IPsec & IGMP</u>
LAYER 2	DATA LINK LAYER	This layer transform data into frames. Protocols: <u>ARP, CSLIP, HDLC, IEEE.802.3, PPP, X-25, SLIP, ATM, SDLS & PLIP</u>
LAYER 1	PHYSICAL LAYER	Deals with hardware of network such as cabling. Define mechanical and electrical standards. Protocols: <u>PON, OTN, DSL, IEEE.802.11, IEEE.802.3, L431 & TIA 449</u>

<https://ipwithease.com>

Prérequis (Modèle TCP/IP)



Prérequis (Notions de Base en Sécurité)

1. C'est quoi la sécurité informatique ?

Objectifs de la sécurité

1. **L'authentification :**
 - consiste à assurer l'identité d'un utilisateur
2. **La confidentialité :**
 - consistant à assurer que seules les personnes autorisées aient accès aux ressources échangées.
3. **L'intégrité :**
 - garantir que les données n'ont pas été altérées durant la communication (de manière fortuite ou intentionnelle).
4. **La non-répudiation :**
 - garantir qu'aucun des correspondants ne pourra nier la transaction.
5. **La disponibilité :**
 - maintenir le bon fonctionnement du système d'information et garantir l'accès à un service ou à des ressources.

Terminologie essentielle

- **Malware :**

(contraction de « malicious software ») désigne tout programme informatique conçu pour infecter et endommager l'ordinateur d'un utilisateur légitime de multiples façons

- **Vulnérabilité:**

Représente le niveau d'exposition face à la menace dans un contexte particulier: n'importe quel défaut matériel ou logiciel qui laisse le réseau ouvert pour une potentielle exploitation. (Types: Physiques, Réseaux, Systèmes et applicatives).

- **Menace :**

action susceptible de nuire dans l'absolu. Il s'agit de toute intention ou méthodes utilisées pour exploiter une vulnérabilité (ou faiblesse) dans un système. Une menace peut être accidentelle ou intentionnelle.

Terminologie essentielle

- **Attaque :**

toute action qui exploite une ou plusieurs vulnérabilités (failles) pour réaliser une menace avec l'intention de nuire.

- **Contre-mesure :**

est l'ensemble des actions mises en œuvre en prévention de la menace.

Exemple

Dans le cas d'une authentification d'un utilisateur pour accéder à son compte mail :

- Vulnérabilité : **envoi de mot de passe non chiffré à travers le réseau**
- Menace :
détournement du mot de passe
- Attaque :
interception du mot de passe par un pirate qui écoute la communication (man-in-the-middle)
- Contre-mesure :
chiffré le mot de passe avant de l'envoyer

Terminologie essentielle

- **Vulnérabilité zero-day :**
 - vulnérabilité n'ayant fait l'objet d'aucune publication ou n'ayant aucun correctif connu.
- **Cyberguère :**
 - guerre cybernétique (en anglais : cyberwarfare),
 - l'utilisation d'ordinateurs et d'Internet pour mener une guerre dans le cyberspace.
 - Il existe deux types :
 - **Défensive** : stratégies et actions pour défendre les biens contre les cyberattaques
 - **Offensive** : implique les attaques contre les biens de l'adversaire

Types ou classes de pirates

- **Black Hat :**

- Hackers malveillants qui exploitent les failles pour des gains illégaux ou causer des dommages.

- **White Hat :**

- Hackers éthiques qui aident à sécuriser les systèmes en trouvant des vulnérabilités avant les criminels.

- **Gray Hat :**

- Hackers non autorisés qui découvrent des failles sans intention malveillante, mais qui peuvent agir à la limite de la légalité.

- **Script Kiddie :**

- Amateurs utilisant des outils prédéfinis sans réelle compétence technique.

Types ou classes de pirates

- **Hacktivist :**

- Hackers motivés par des causes politiques ou sociales, lançant des cyberattaques pour défendre leurs convictions. **The Fifth Estate (2013) : Ce film raconte l'histoire de Julian Assange et de son site WikiLeaks (rapports militaires et diplomatiques, violations des droits de l'homme, corruption ..)**

- **Red Team/Blue Team Hackers :**

- **Red Team** : Hackers simulant des attaques pour tester la sécurité des systèmes d'une organisation.
- **Blue Team** : Experts en sécurité qui défendent activement les systèmes contre les attaques.

Ingénierie sociale : (social engineering)

L'ingénierie sociale est une méthode d'attaque qui **exploite des failles humaines** pour obtenir des **informations sensibles** ou un accès non autorisé.

Elle **repose** sur la **manipulation psychologique** plutôt que sur des failles techniques, en poussant les victimes à **divulguer volontairement** des données ou à exécuter des actions compromettantes.

Ingénierie sociale : (social engineering)

Exemples courants :

1. Phishing :

emails frauduleux, imitent souvent des communications, incitant à révéler des identifiants.

2. Baiting :

appât pour inciter à télécharger un logiciel malveillant.

Rappel (Séance 1)

- ISO/TCP-IP
- Objectifs de sécurité
- Vulnérabilité, Menace, Attaque, Zéro Day
- Types de Hackers

Les phases d'une attaque

- Supposons que je veuille faire une attaque informatique sur une cible **X** ! À votre avis, quelle est la première étape à réaliser ?

1. Reconnaissance

Phase 1 : Reconnaissance

- Phase préparatoire durant laquelle l'attaquant cherche à collecter les informations à propos de la cible avant de lancer l'attaque.
- **Objectif:** découverte des systèmes, services ou vulnérabilités.
- L'attaquant **extraie des informations sur** : les machines actives, ports, états des ports, système d'exploitation, types d'équipements, etc.
- Cette phase permet à l'attaquant de choisir le vecteur d'attaque pour s'introduire dans le système, il peut s'agir d'un exploit 0-day ou d'une campagne de phishing.

Reconnaissance

- **Reconnaissance passive** : acquérir les informations sans entrer en contact avec la cible, l'attaquant collectera des informations sur la victime
 - à partir des sources publiques (moteurs de recherche),
 - ou les réseaux sociaux tels que Facebook, LinkedIn, etc.
- **Reconnaissance active** : désigne l'interaction directe avec la cible par n'importe quel moyen :
 - les scanneurs des ports tel que Nmap ;
 - et les analyseurs de paquets tels que Wireshark.

Reconnaissance

- 1) Prenez comme exemple le site:
 - 2) <https://www.dzfoot.com/>
- 3) Comment vous allez faire pour collecter des informations sur le site (entreprise) ?
- 4) @IP du serveur ?

Reconnaissance

Python (socket)

```
import socket
```

```
ip_address =  
socket.gethostbyname('www.dzfoot.com')
```

```
print(f"IP : {ip_address}")
```

Les phases d'une attaque

- Reconnaissance
- Intrusion et présence

Phase 2 : Intrusion et présence

- Diffère selon l'objectif et le type d'attaque.
- Dans le cas d'attaque d'accès, l'attaquant tente de gagner l'accès soit au niveau système d'exploitation, application, ou réseau.
- Ensuite, il essaie d'élever ses privilèges pour obtenir un contrôle total du système (pour toujours).
- Les attaques d'accès emploient souvent des techniques de brute force pour trouver les mots de passe, les chevaux de troie, l'usurpation d'adresse ip, et l'analyse de paquets.

Les phases d'une attaque

- Reconnaissance
- Intrusion et présence
- Effacement des traces

Phase 3 : Effacer les traces

- L'attaquant efface ses traces (logs applications et système) afin de cacher ses actions et activités malveillantes et rester indétectable.

Les phases (**Vecteur**) d'une attaque

- Reconnaissance
 - Information Gathering
 - Target Discovery
 - Vulnerability mapping
- Intrusion et présence
 - Social Engineering
 - Target exploitation
 - Privilege escalation
 - Maintaining access
- Effacement des traces

Les phases (**Vecteur**) d'une attaque

- En pentesting, à votre avis, quelle est la phase supplémentaire ?

Documentation and reporting

Domaines de la sécurité

- Il existe 12 domaines de sécurité spécifiés dans l' **ISO/IEC 27002**
- Évaluation des risques et de traitement (Chapitre n° 4)
- Politiques de sécurité de l'information (Chapitre n° 5)
- Gestion des incidents liés à la sécurité de l'information (Chapitre n° 16)